

CNCJ: 認証認可セキュリティミートアップ : Identity Next

AIエージェントの認証・認可

Keycloak と Athenz で実装する

RFC 8693(Token Exchange) と ID-JAG による Identity Chaining

LINEヤフー株式会社

矢野 達也

2026/02/25

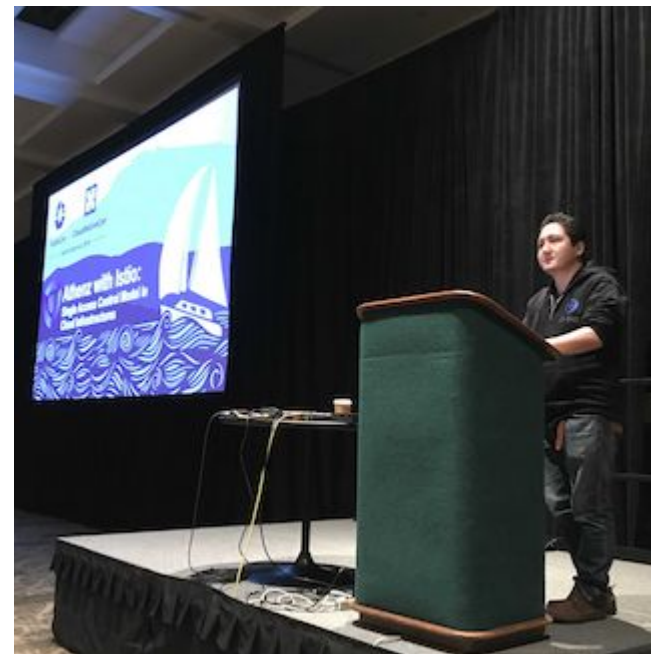
LINEヤフー

矢野 達也

Tatsuya Yano

Athenz Open Source Community Member
LY Corporation Athenz Product Owner

- 社内アクセス制御基盤システムのDevSecOps
- Athenz Open Source Community発足に携わり、現在までContributionを継続
- CNCF Eventにおける過去の登壇
 - Open Source Summit Japan 2018
 - KubeCon North America 2018
- 過去のMeetup
 - SPIFFE Meetup Tokyo #1, #3
 - #cTENCf Birthday Bash Tokyo



本日のアジェンダ

- 01 Identity Next: デジタルIDのパラダイムシフト
- 02 AI Agent の普及に伴う認証・認可の課題
- 03 解決策：Identity Chaining
- 04 ユーザ認証 と RFC 8693 Token Exchange
- 05 ワークロード認証 と Identity Provisioning
- 06 Cloud Native なゼロトラスト基盤の実現とまとめ

本日のアジェンダ

01 Identity Next: デジタルIDのパラダイムシフト

02 AI Agent の普及に伴う認証・認可の課題

03 解決策：Identity Chaining

04 Keycloak と RFC 8693 Token Exchange

05 Athenz によるワークロード認証

06 Cloud Native なゼロトラスト基盤の実現とまとめ

Identity Next

デジタルアイデンティティの パラダイムシフト

クラウドネイティブ時代のアイデンティティは、静的な「管理」から動的な「連鎖」へと進化しています。

境界型防御の崩壊に伴い、「誰が (Who)」と「何が (What)」を厳密に区別し、追跡性を高める必要が出てきています。

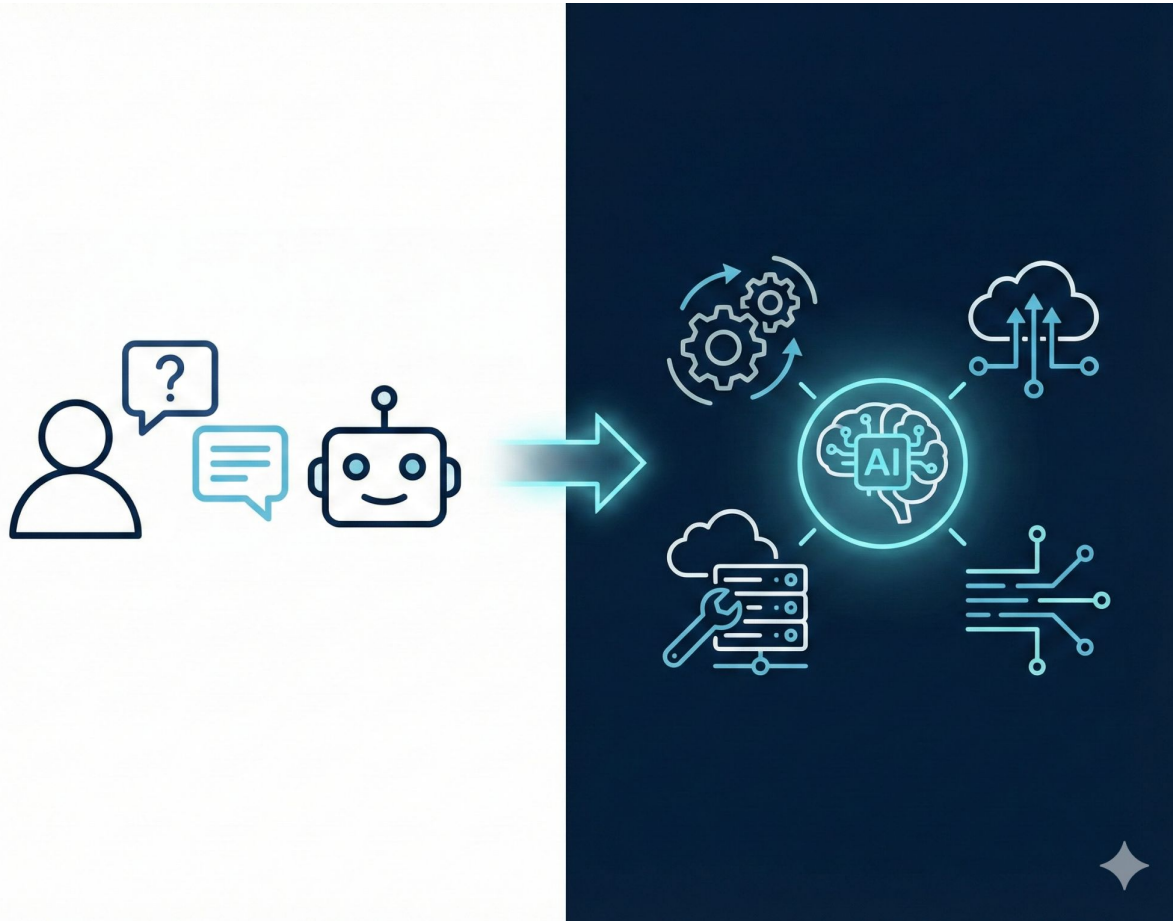
チャットボットから エージェントへ

AIエージェント時代の到来
受動的から能動的へ

Model Context Protocol (MCP) と 自律型エージェントのセキュリティ課題

これまでのAIは、人間が質問し、AIが答える
だけでした。

これからのAIエージェントは、ユーザーの
意図を汲み取り、自律的に外部ツールを操
作し、インフラを変更します。



※ 生成AI Geminiによる図出力

本日のアジェンダ

01 Identity Next: デジタルIDのパラダイムシフト

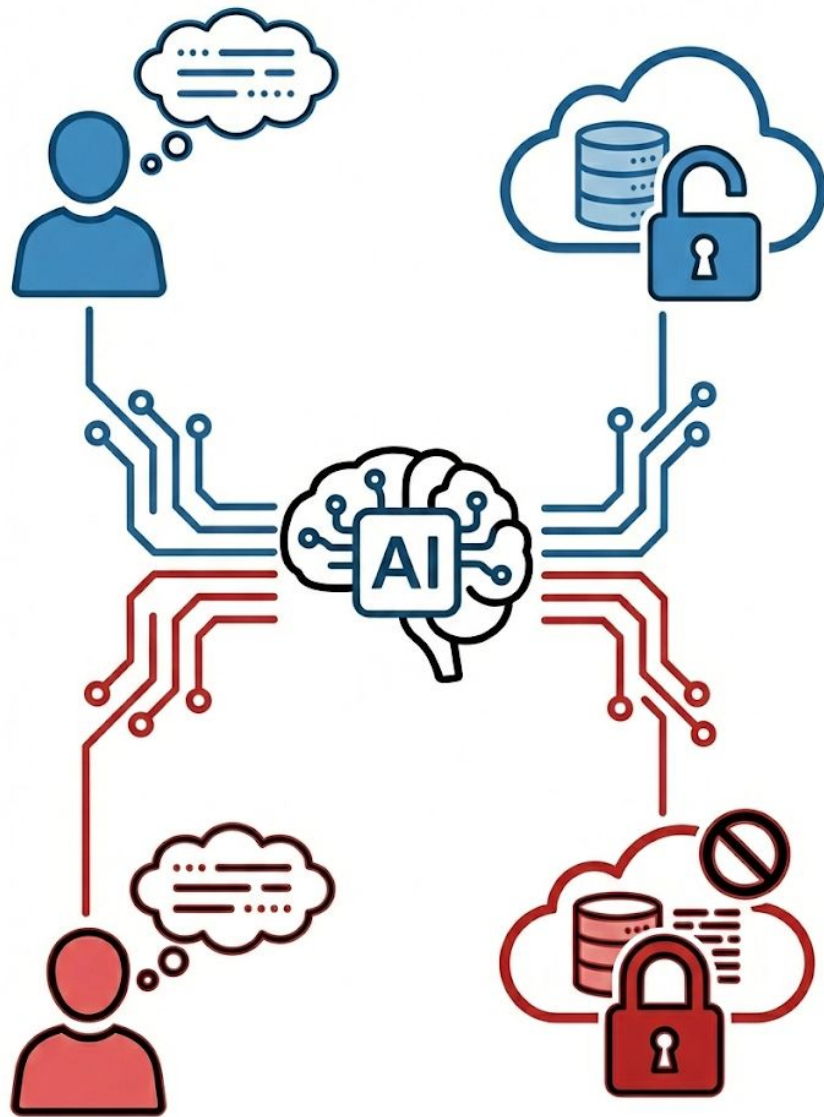
02 AI Agent の普及に伴う認証・認可の課題

03 解決策：Identity Chaining

04 ユーザ認証 と RFC 8693 Token Exchange

05 ワークロード認証 と Identity Provisioning

06 Cloud Native なゼロトラスト基盤の実現とまとめ



※ 生成AI Geminiによる図出力

Confused Deputy 問題

(混乱した代理人)

AIエージェント時代のセキュリティ課題

1. AIエージェントが単一の強力な権限（サービスアカウント）を持つことで、ユーザーが本来アクセス権を持たないデータまで、ユーザーの指示によって操作できてしまう
2. 悪意あるユーザーがプロンプトを通じて、本来アクセス権のないデータをエージェント経由で取得できてしまう

従来の標準：OAuth Client Credentials Grant

サービス間通信でよく使われる client_credentials フローの問題点：

ERROR: User Context is LOST.

- ⚠ 「誰の依頼で」 処理しているかが不明になる。
- ⚠ すべてのリクエストが「AIエージェント権限」で実行されてしまう。
- ⚠ 監査ログにユーザーIDが残らない。

本日のアジェンダ

01 Identity Next: デジタルIDのパラダイムシフト

02 AI Agent の普及に伴う認証・認可の課題

03 解決策：Identity Chaining

04 ユーザ認証 と RFC 8693 Token Exchange

05 ワークロード認証 と Identity Provisioning

06 Cloud Native なゼロトラスト基盤の実現とまとめ

解決策：Identity Chaining

**「誰の意志 (User Context)」で
「どのプログラム (Workload Context)」が動いているか？**

この2つのコンテキストを分離せず、連鎖（Chain）させて維持し続けることが必要です。

新たな標準規格

Token Exchange と ID-JAG

RFC 8693: Token Exchange

信頼されたクライアントが、あるトークンを別のトークンに交換するプロトコル。

上流ユーザーのトークンを元に、下流サービス専用のトークンを取得可能になります。

```
POST /token grant_type=urn:ietf:params:oauth:grant-type:token-exchange subject_token=[User's  
Original Access Token] requested_token_type=urn:ietf:params:oauth:token-type:access_token
```

ID-JAG

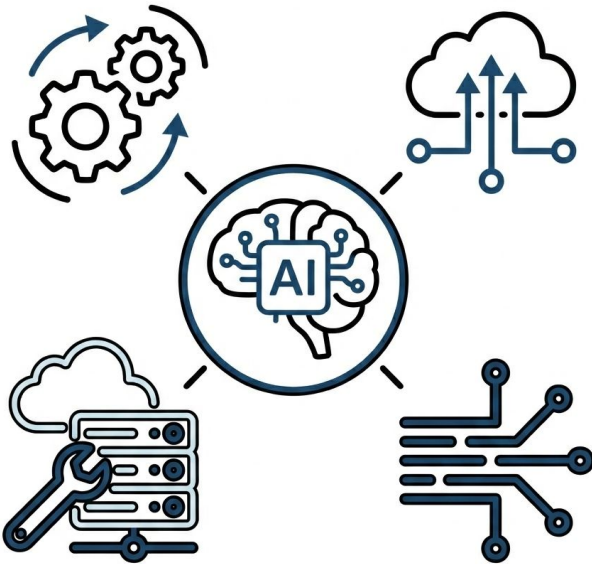
(Identity Assertion JWT Authorization Grant)

IDaaS である Okta を提供する Okta Inc. によって、IETF に提出された、Token Exchange を一歩進めた、ドメインを跨ぐアイデンティティ連携の新標準。

Identity Provider が「紹介状」を発行し、これを Authorization Server に送信して、アクセストークンと交換します。

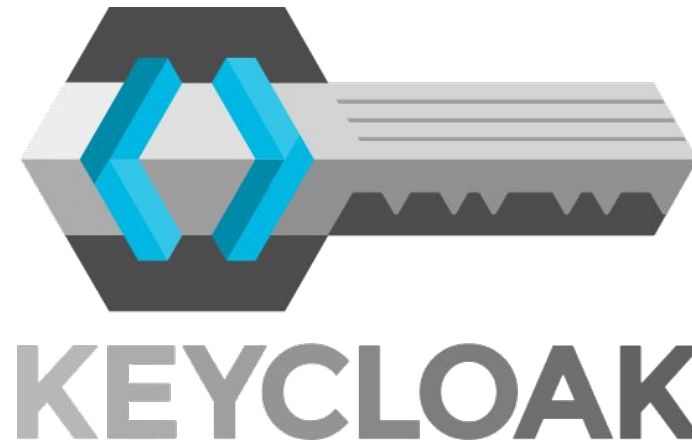
ID-JAG - 本日のキープレイヤー

AI Agent



※ 生成AI Geminiによる図出力

User 認証 Identity Provider



Workload 認 証

Authorization Server

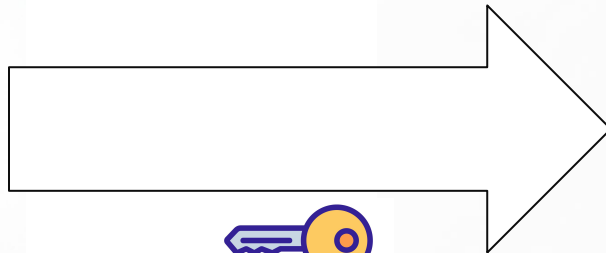
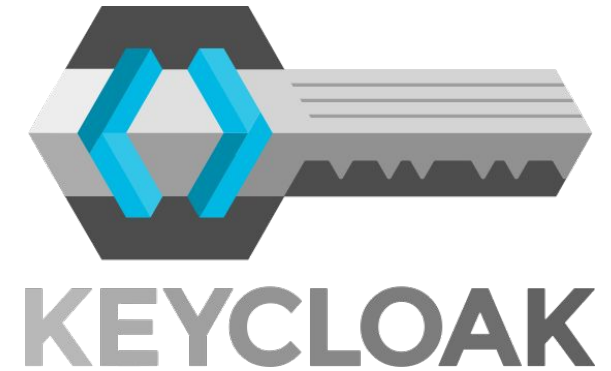


Athenz

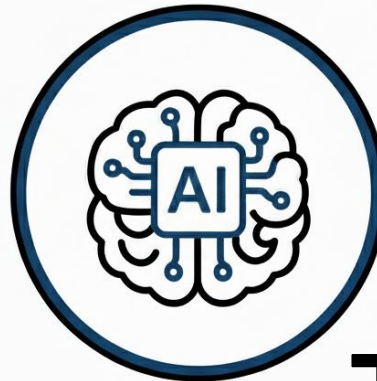
※ 生成AI Geminiによる図出力

従来のフロー

SSO Login



Pass PAT

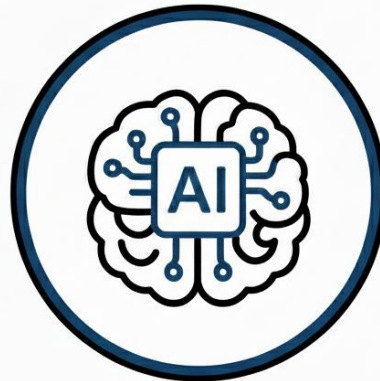
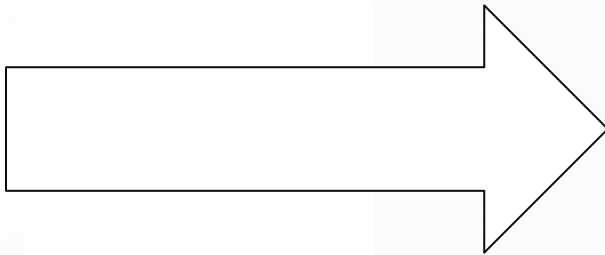
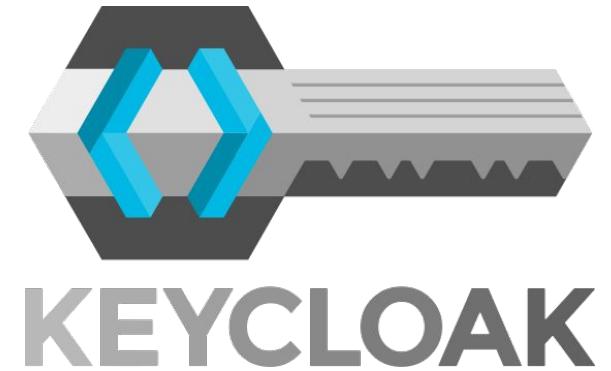


Token Auth



ID-JAG - Step 1: ユーザーログイン

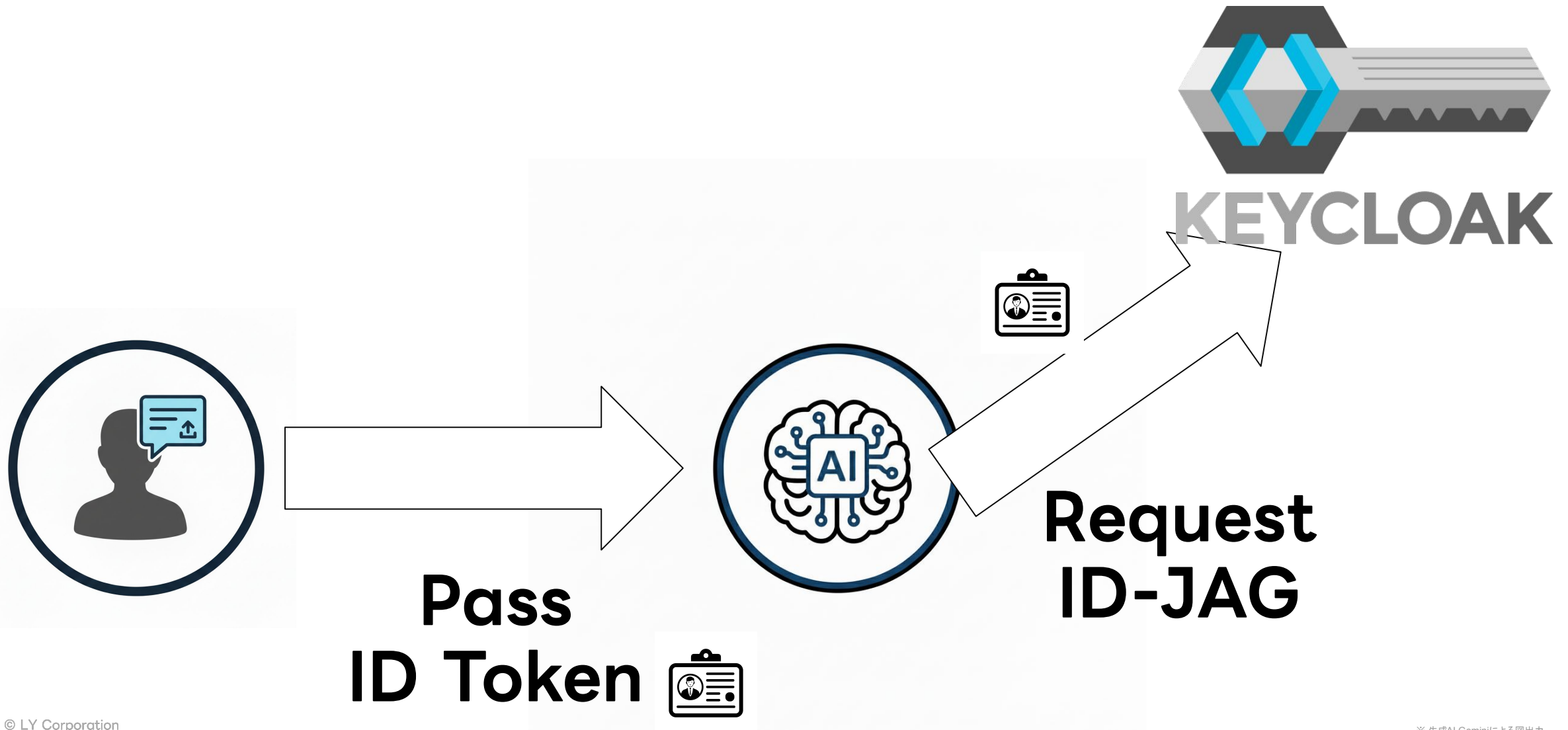
SSO Login



Pass
ID Token



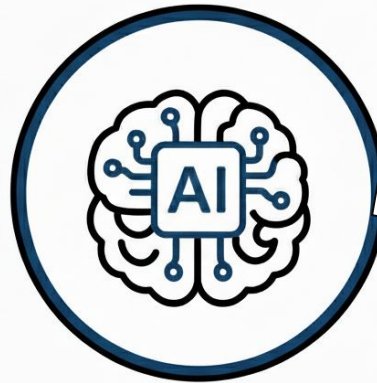
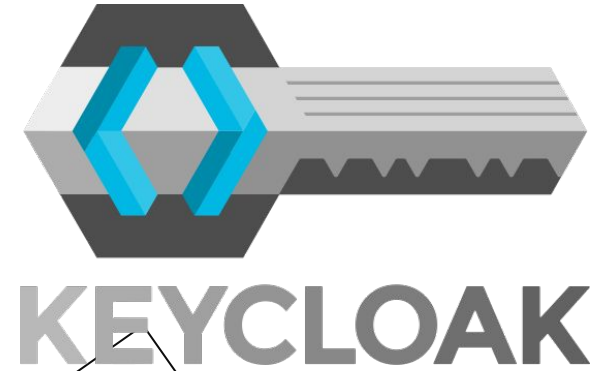
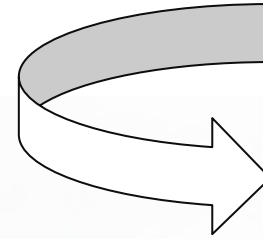
ID-JAG - Step 2: Token Exchange



ID-JAG - Step 3: ID-JAG 発行



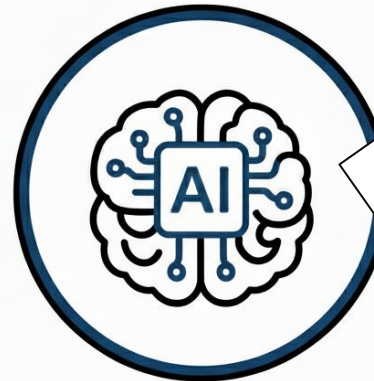
**Check
Company Policy**



ID-JAG

ID-JAG - Step 4: Token Exchange

**Check
Company Policy**
(Role-Based Access Control)



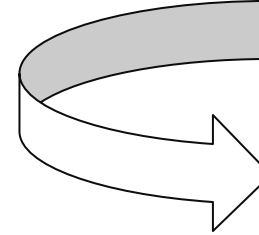
ID-JAG

**AI Agent
Certificate**

**Request
Access Token**

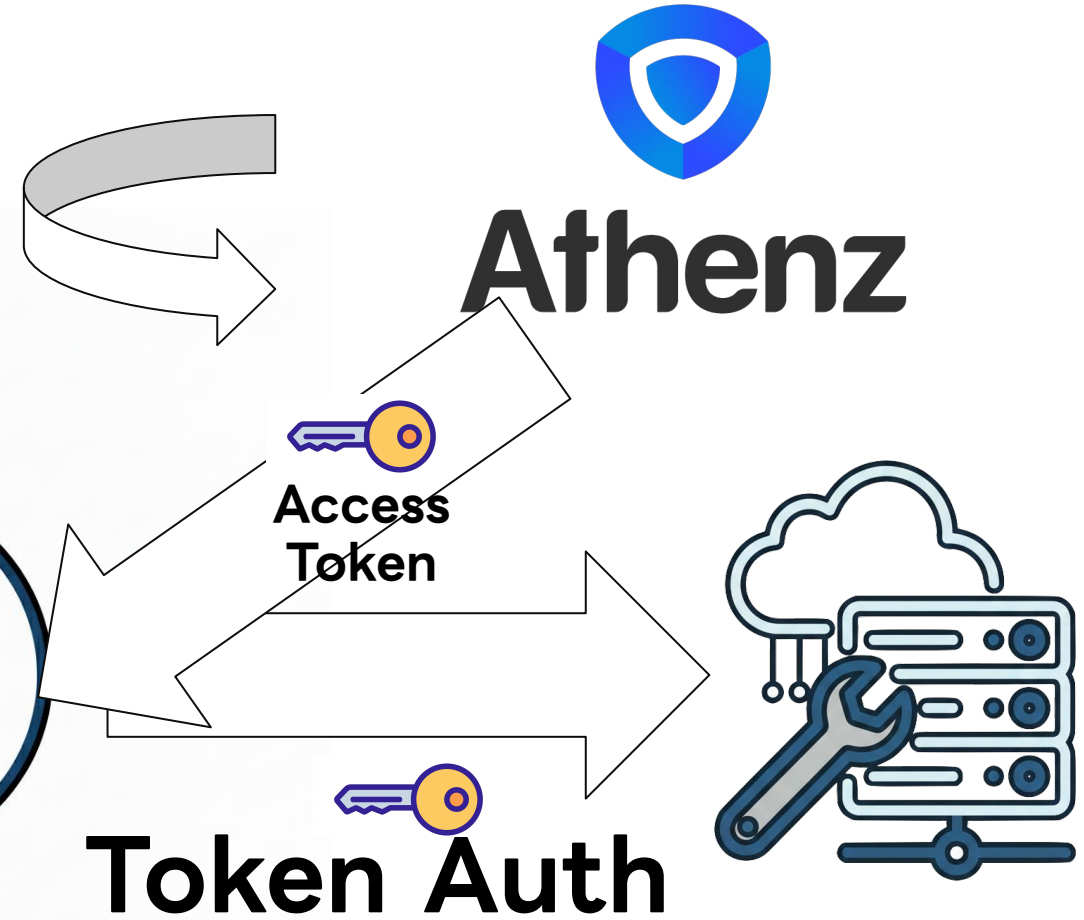
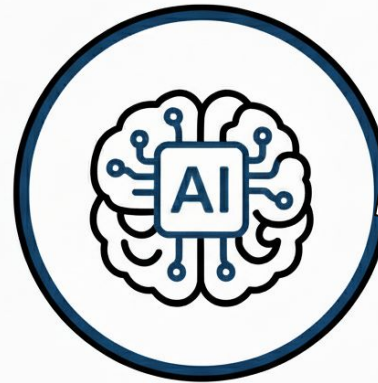


Athenz



ID-JAG - Step 5: 検証と実行

**Check
Company Policy**
(Role-Based Access Control)

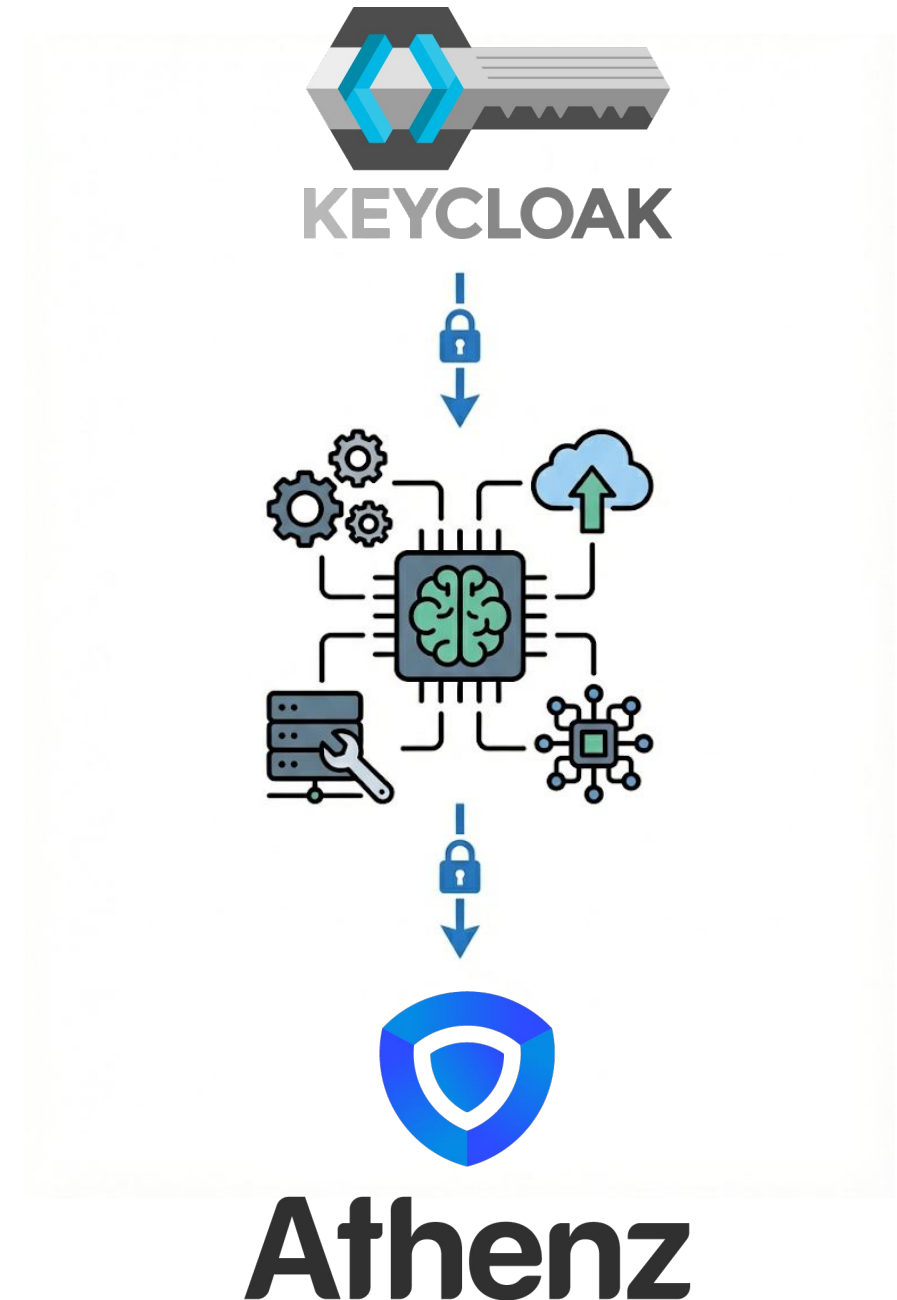


「サンドイッチ」モデル

強固な認証を組み合わせて実現

通信の外側と内側で異なるアイデンティティ検証を行う。

- **外側** (Transport / Proxy): Athenz mTLS / JWT
「この通信は正しい**エージェント**から来ているか？」
- **内側** (Application): Keycloak ID-JAG
「このリクエストは正しい**ユーザー**の意志か？」



統合アーキテクチャ: Identity Chaining

Keycloak (User) + Athenz (Workload) の融合

本日のアジェンダ

01 Identity Next: デジタルIDのパラダイムシフト

02 AI Agent の普及に伴う認証・認可の課題

03 解決策：Identity Chaining

04 ユーザ認証 と RFC 8693 Token Exchange

05 ワークロード認証 と Identity Provisioning

06 Cloud Native なゼロトラスト基盤の実現とまとめ

Keycloak

ユーザー認証と連携

Token Exchange と ID-JAG によるユーザー認証の架け橋

ユーザー認証における SSoT

- 様々なセキュリティ標準プロトコルをサポートするOSS
- OAuth 2.0 / OIDC の最先端標準の実装を主導
- CNCF Incubating Project
- FAPI (Financial-grade API),
CIBA (Client-Initiated Backchannel Authentication)

[About](#) [Projects](#) [Training](#) [Community](#) [Blog & News](#)[Join](#)

PROJECTS

Keycloak



Keycloak is an open-source identity and access management solution for modern applications and services, built on top of industry security standard protocols.

Keycloak was accepted to CNCF on April 10, 2023 at the **Incubating** maturity level.

[VISIT PROJECT WEBSITE](#)

Keycloakでの実装状況

コミュニティによる貢献により、Keycloak 26.5以降でプレビュー機能として開発が進んでいます。

<https://www.keycloak.org/2026/01/jwt-authorization-grant>



GitHub Stars 33k

[Guides](#) [Docs](#) [Downloads](#) [Community](#) [Blog](#)

JWT Authorization Grant and Identity Chaining in Keycloak 26.5

January 23 2026 by Giuseppe Graziano

Modern applications and AI agents increasingly operate across distributed trust domains, where each domain is protected by its own OAuth 2.0 Authorization Server. A single request may also traverse multiple resource servers to complete a task.

This raises an important challenge: every protected resource must understand **who initiated the request**, which **authorization** was granted, and optionally which other resources were accessed before making an authorization decision. Preserving this information across domains is critical.

Keycloak 26.5 introduces **preview** support for the new feature **JWT Authorization Grant**, implementing [RFC 7523](#). This feature allows a client to present a signed JWT from an external issuer and obtain a Keycloak access token, providing a **standard and secure way to authorize requests based on external assertions**.

However, exchanging a token alone does not fully solve the problem of propagating identity and authorization context across multiple trust domains.

The IETF draft **OAuth Identity and Authorization Chaining Across Domains** defines a standardized flow that combines **JWT Authorization Grant (RFC 7523)** with **OAuth 2.0 Token Exchange (RFC 8693)**, which **Keycloak already supports**, to preserve the original user's identity, claims, and authorization throughout the chain.

本日のアジェンダ

- 01 Identity Next: デジタルIDのパラダイムシフト
- 02 AI Agent の普及に伴う認証・認可の課題
- 03 解決策：Identity Chaining
- 04 ユーザ認証 と RFC 8693 Token Exchange
- 05 ワークロード認証 と Identity Provisioning**
- 06 Cloud Native なゼロトラスト基盤の実現とまとめ

Athenz

ワークロード認証の基盤

IPアドレス依存からの脱却 と SPIFFE 標準認証

ワークロード認証・認可における SSoT

- ハイブリッドクラウド認証を一括管理するOSS
- Identity配布から権限管理まで、必要な機能をワンストップ提供
- OAuth / OIDC / mTLS 準拠の実装
- CNCF Sandbox Project
- SPIFFE (Secure Production Identity Framework for Everyone), ID-JAG (Identity-Assertion JWT Authorization Grant)

CLOUD NATIVE
COMPUTING FOUNDATION

AboutProjectsTrainingCommunityBlog & News

Join

Q

PROJECTS

Athenz


Athenz

Open source platform for X.509 certificate based service authentication and fine grained access control in dynamic infrastructures

Athenz was accepted to CNCF on January 26, 2021 at the **Sandbox** maturity level.

VISIT PROJECT WEBSITE



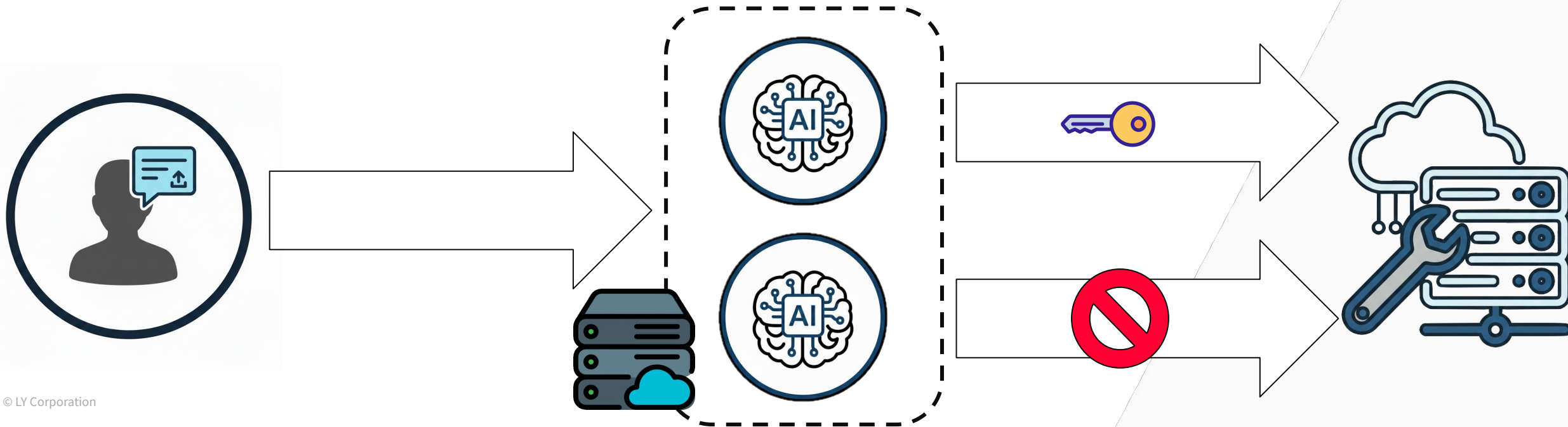


従来の課題：IPアドレスベースの限界

- 動的な環境: Kubernetes の Pod や AWS Lambda は IP が頻繁に変わる。
- 境界の消失: ゼロトラスト環境ではネットワーク上の「場所」を信頼できない。
- Athenz の解答: ネットワーク上の場所ではなく、公開鍵暗号で検証可能な「ID証明書」を付与



Athenz

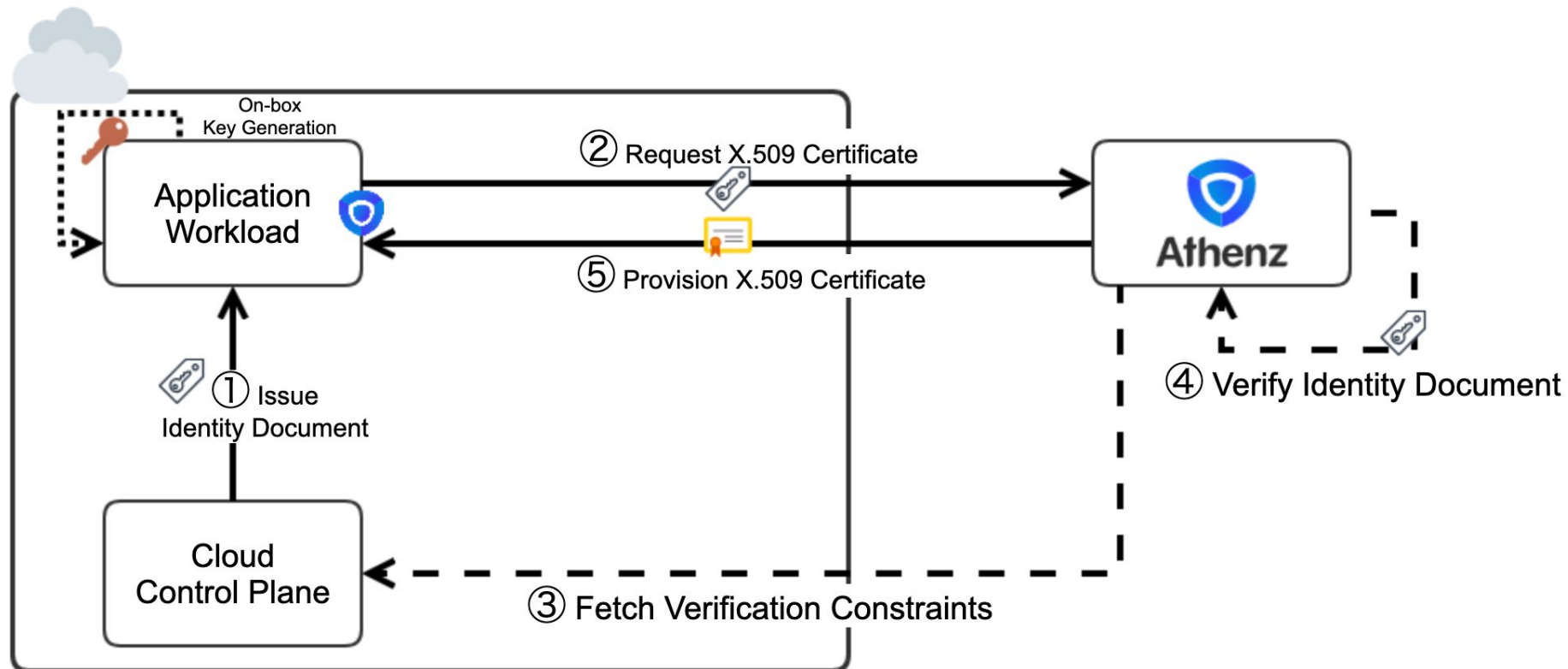


Identity Provisioning: 信頼の自動プロビジョニング

～ Athenz 「Copper Argos」 による、信頼に基づいたアイデンティティ配布 ～

Q: 「何も持たないワークロードが、どうやって最初の証明書を得るか？」

A: クラウドプロバイダーの信頼を起点に、Athenz の信頼を確立する仕組み

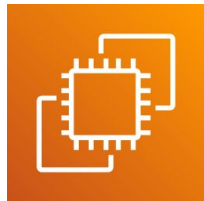


Copper Argos: 環境に合わせた信頼を構築

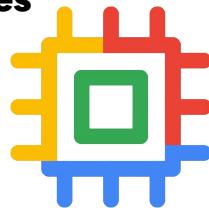
VM



Azure
Virtual Machines



AWS EC2

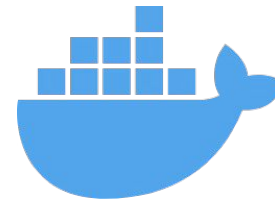


Google
Compute
Engine

Container



kubernetes



Docker



AWS ECS



AWS EKS

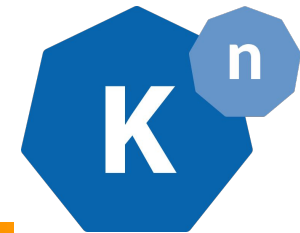


Azure
Kubernetes
Service



Google
Kubernetes Engine

Serverless



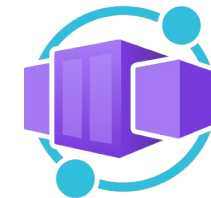
Knative



AWS Lambda



Google
Cloud Run

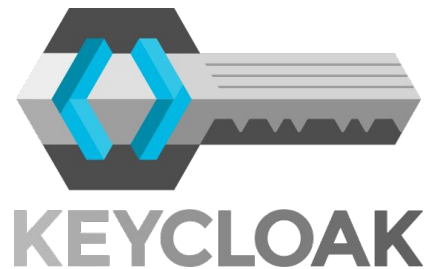


Azure
Container Apps

コミュニティにおける最新の動向

Keycloak (v26.2+)

- Token Exchange 正式サポート (GA) 🎉
- ID-JAG/Identity Chaining実装の推進



Athenz (v1.12.32+)

- Token Exchange 対応 (PR #3148) 🎉
- ID-JAG による User/Workload 認証に対応



本日のアジェンダ

- 01 Identity Next: デジタルIDのパラダイムシフト
- 02 AI Agent の普及に伴う認証・認可の課題
- 03 解決策：Identity Chaining
- 04 ユーザ認証 と RFC 8693 Token Exchange
- 05 ワークロード認証 と Identity Provisioning
- 06 Cloud Native なゼロトラスト基盤の実現とまとめ**

メリット1: AIのためのゼロトラスト

暗黙の信頼を排除

- 「社内ネットワークだから安心」
「自分が実行したエージェントだから安心」
という考え方を排除。
- すべてのリクエストに対して、
人間のIDと**ワークロードのID**の
両方を検証します。



※ 生成AI Geminiによる図出力

メリット2: 監査可能性 (Auditability) と即時失効 (Instant Revocation)

1. ログに「誰の代理で」実行されたかが明確に残ります。
→ インシデント発生時の**追跡調査が容易**になります。
2. ID-JAG や Access Token は短命な有効期限を持ち、
発行ポリシーが Keycloak や Athenz で中央管理されます。
→ 不正アクセスが疑われた際には、**即時失効が可能**になります。

```
TIMESTAMP: 2026-02-25 18:00:00 Action: DROP TABLE users AGENT: ai-agent-v1 (Athenz Workload ID)  
ON_BEHALF_OF: yano (Keycloak User ID) RESULT: DENIED
```

メリット3: CNCF 相互運用性

Open Standards

オープンスタンダードに準拠

- OAuth
- Token Exchange
- SPIFFE
- OIDC



No Vendor Lock-in

特定クラウドベンダーに依存せず、
マルチクラウド・ハイブリッドクラウド
で動作



本日のアジェンダ

- 01 Identity Next: デジタルIDのパラダイムシフト
- 02 AI Agent ・ MCP の台頭による認証・認可の課題
- 03 解決策：Identity Chaining アーキテクチャ詳細
- 04 ユーザ認証 と RFC 8693 Token Exchange
- 05 ワークロード認証 と Identity Provisioning
- 06 ゼロトラスト基盤の実現とまとめ

ご清聴ありがとうございました。

Appendix

Appendix - MCP

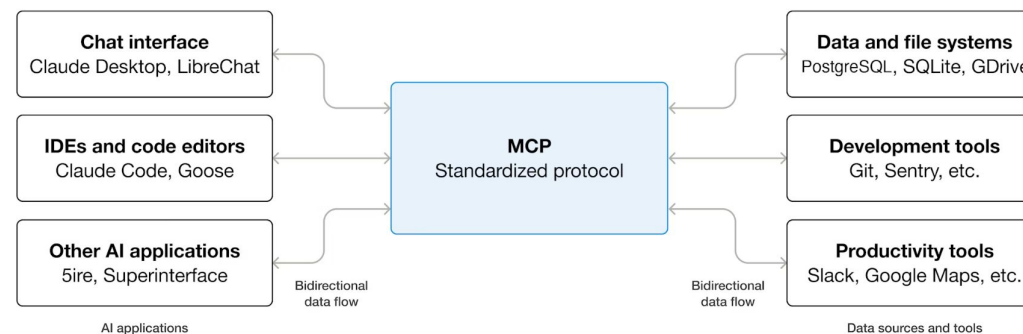
MCP (Model Context Protocol) とは？

AIとツールの標準インターフェース

Anthropic社によって提唱された標準規格。

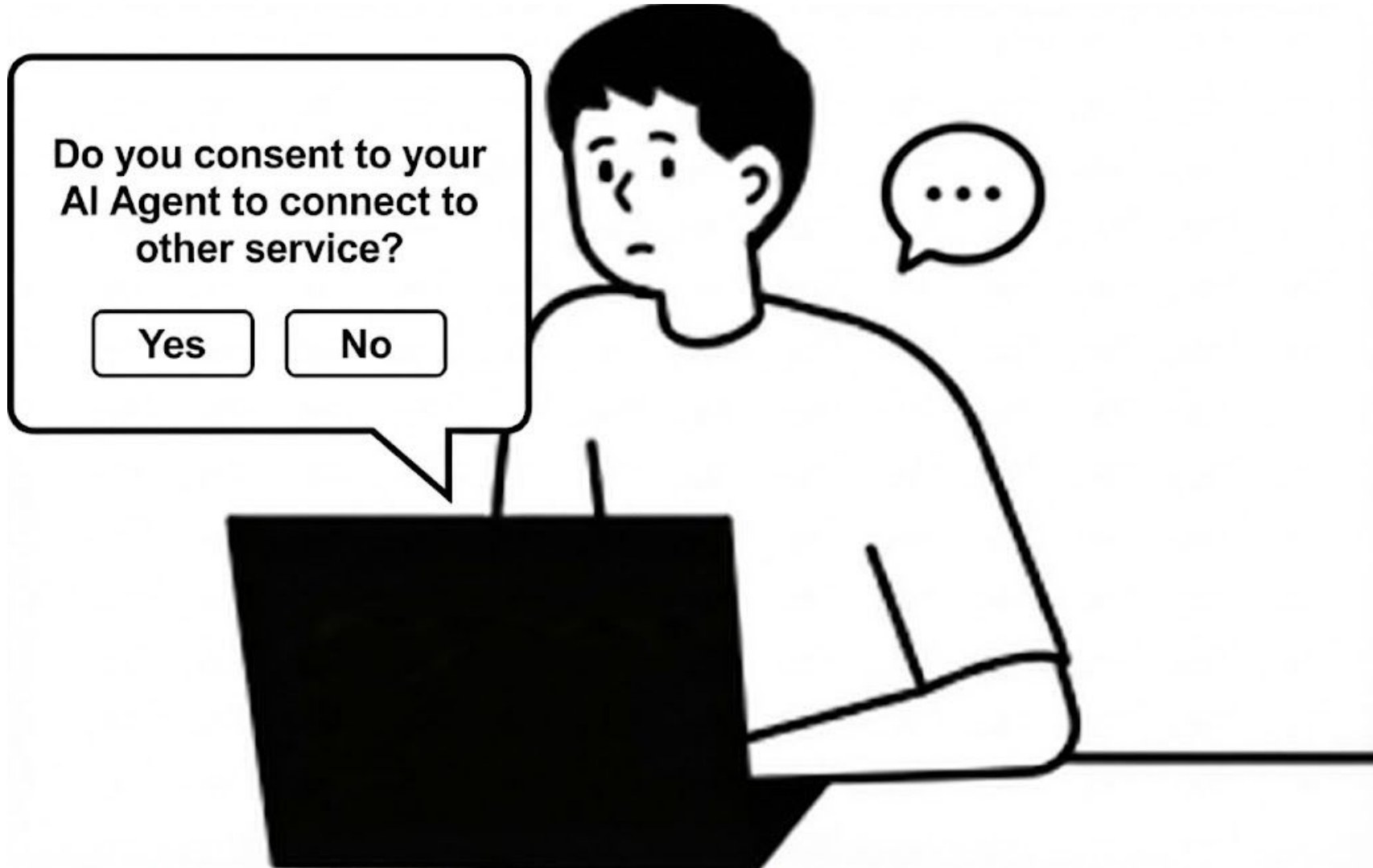
LLMが外部のデータソースやツール（API、DB、ファイル）に接続するための共通プロトコルを提供します。

まるで「USB-C」のように、プラグアンドプレイでツールを接続可能にするものです。

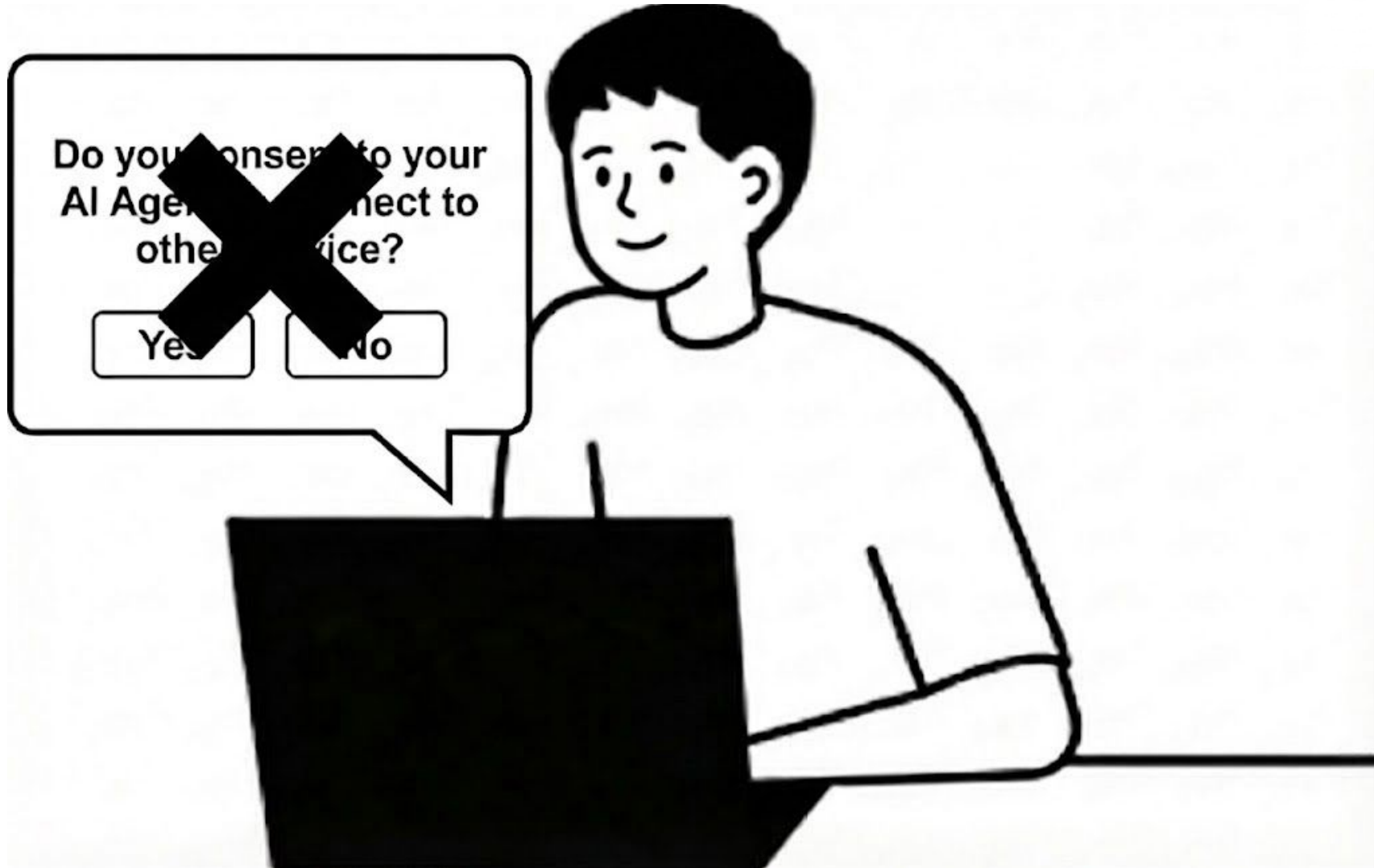


Appendix - ID-JAG

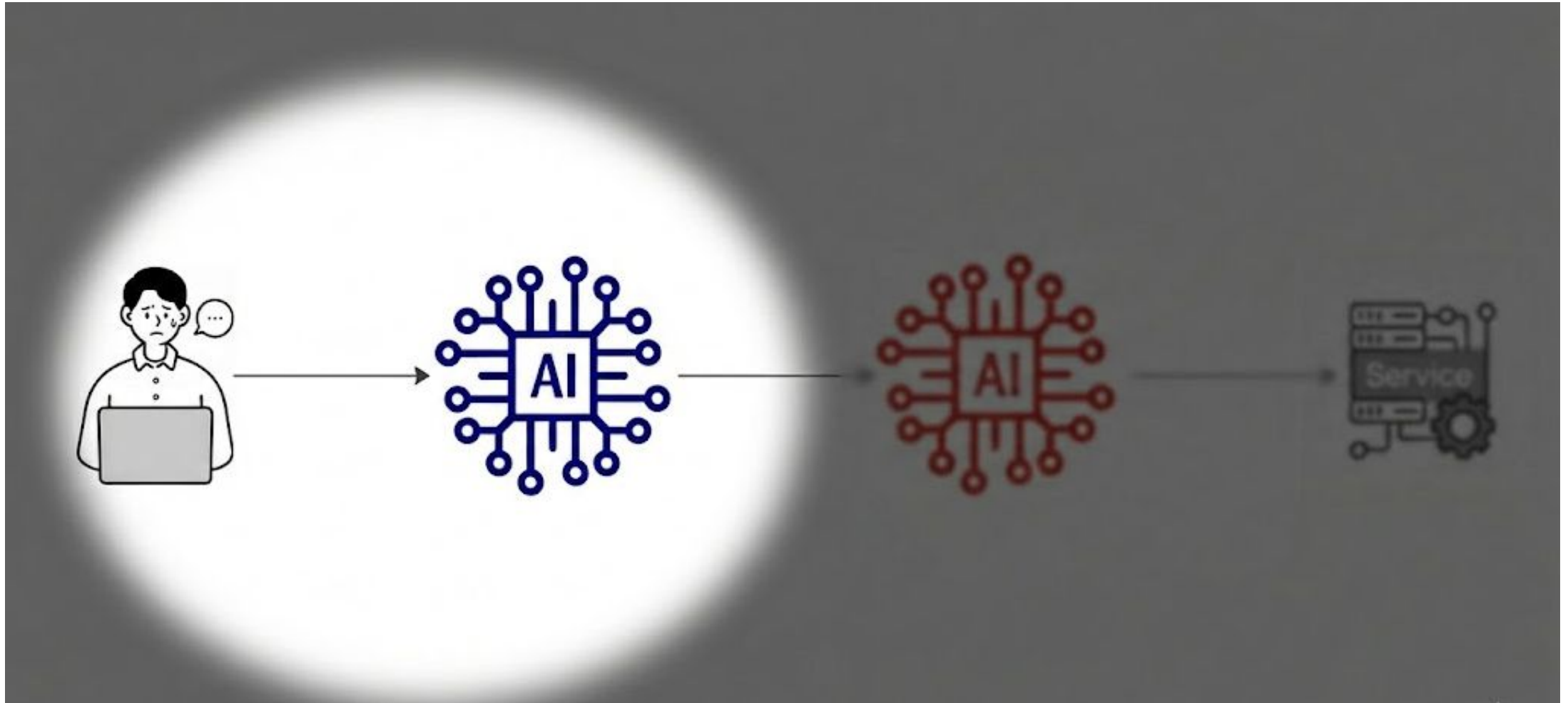
Benefit 1 of 4: No More User Consent



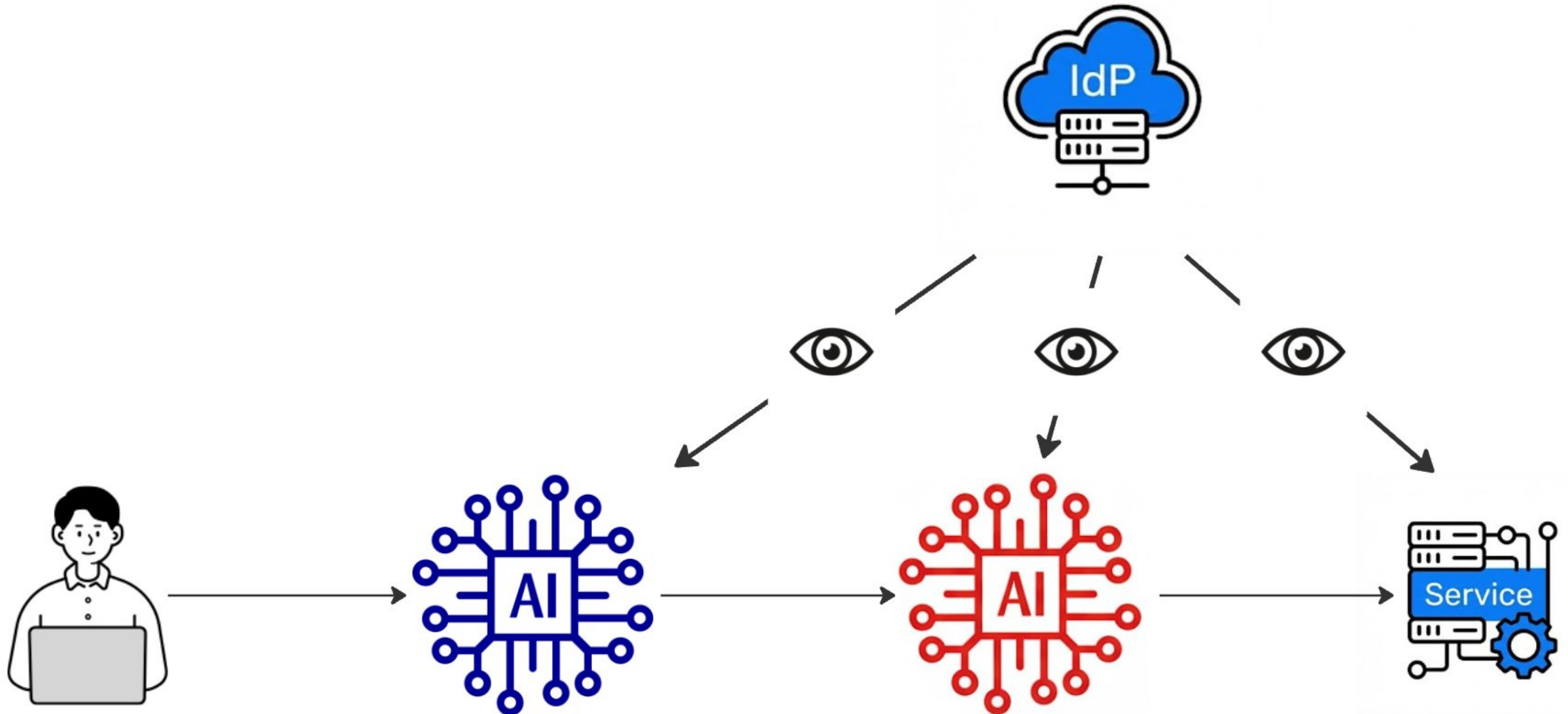
Benefit 1 of 4: No More User Consent



Benefit 2 of 4: Organizational Visibility



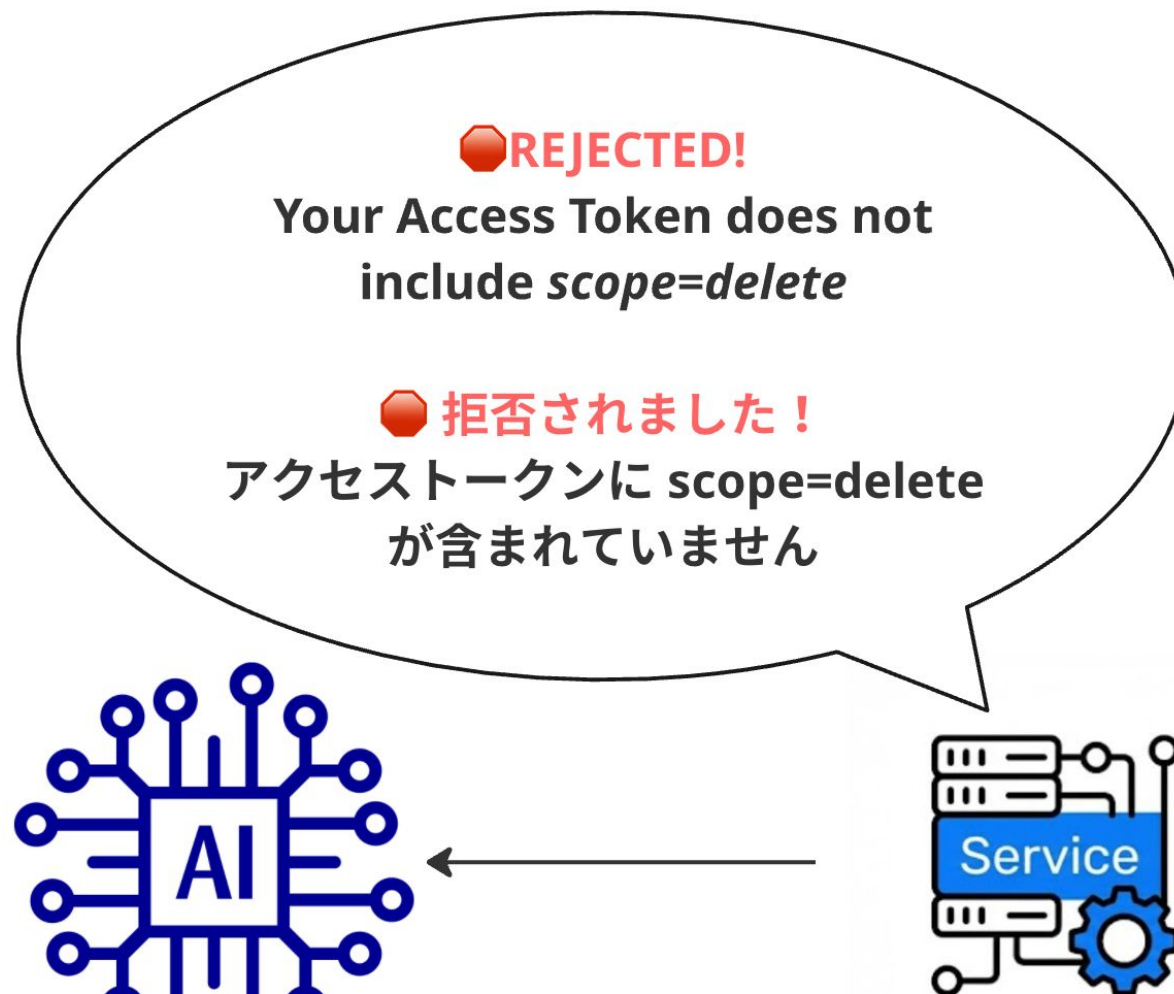
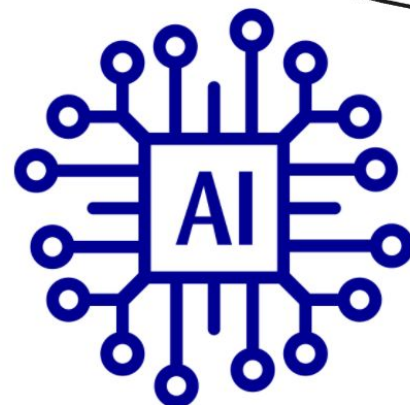
Benefit 2 of 4: Organizational Visibility



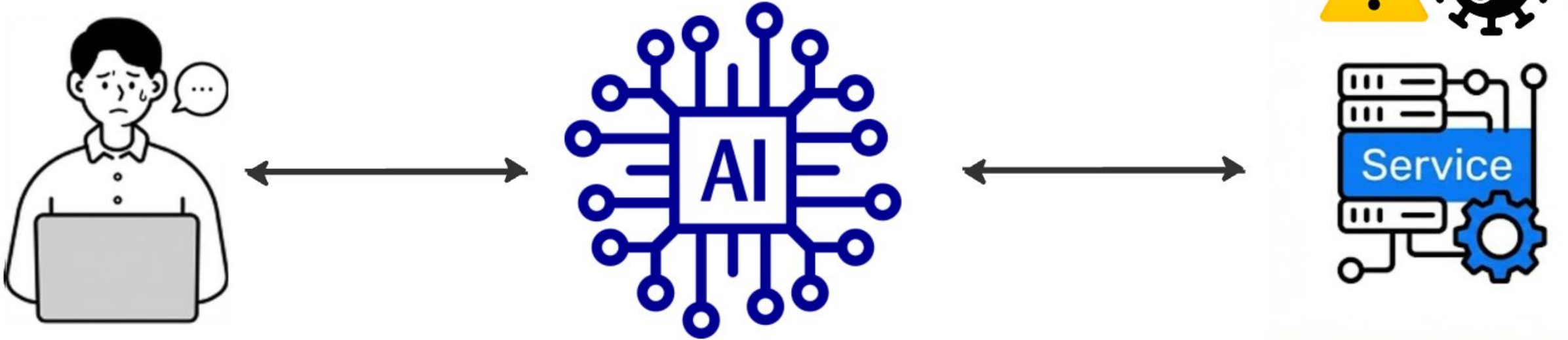
Benefit 3 of 4: Safety Net



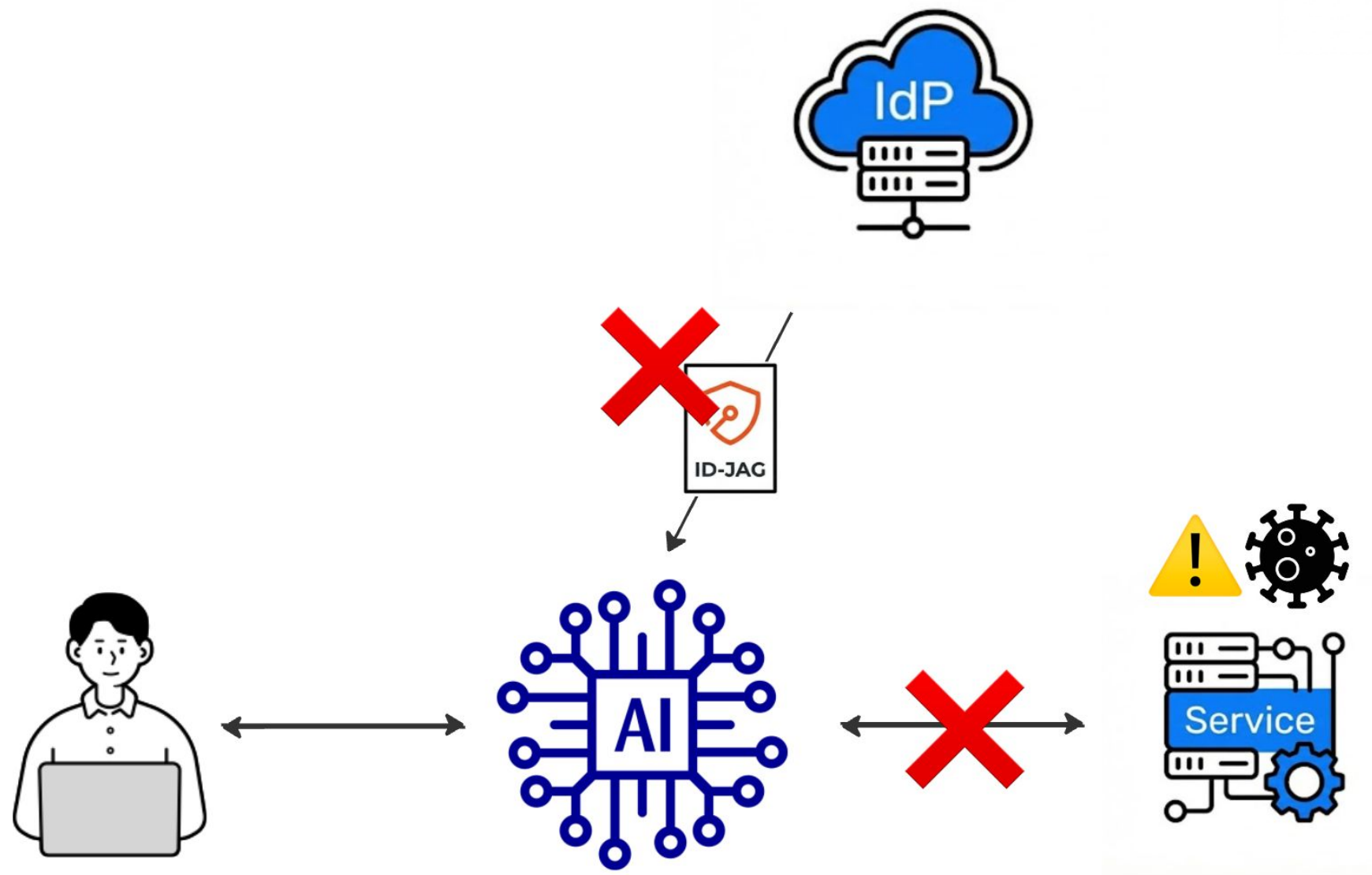
Benefit 3 of 4: Safety Net



Benefit 4 of 4: Instant Revocation



Benefit 4 of 4: Instant Revocation



Appendix - Athenz

Athenz アーキテクチャ概要

環境を問わず、クラウドアプリケーションに必要な「認証・認可」機能を One-stop 提供

